

Informe FAICP 2025–2026 — Parte II: NIST AI RMF, OWASP LLM Top 10, AESIA y el Plan Nacional de Ciberseguridad de España

"Medir sin gobernar es estadística; gobernar sin medir es fe ciega. La ciberseguridad de la IA exige ambas cosas al mismo tiempo, y con elegancia."

11. El NIST AI RMF 1.0 como Marco Complementario al Cyber AI Profile

11.1. Las Cuatro Funciones del AI RMF y sus KPIs

Mientras el NIST IR 8596 (Cyber AI Profile) extiende el CSF 2.0 hacia la intersección IA-ciberseguridad, el **NIST AI Risk Management Framework 1.0** (AI 100-1, enero 2023, actualizado con documentación complementaria en 2025) aporta la dimensión de **gestión del riesgo del ciclo de vida completo del sistema de IA**, incluyendo aspectos de fiabilidad, equidad, explicabilidad y privacidad. Ambos marcos son complementarios y no redundantes: el Cyber AI Profile se ocupa del *cómo proteger* y el AI RMF del *qué gestionar*.^{[1][2]}

Las cuatro funciones del AI RMF —**Gobernar, Mapear, Medir, Gestionar**— generan un total de 19 categorías y más de 70 subcategorías de acción. Sus KPIs de referencia, según la guía de implementación 2025, son:^{[3][4]}

KPIs de la Función GOBERNAR (AI RMF):

- % de usos de IA con propietario asignado y nivel de riesgo documentado
- Tasa de completitud del *Acceptable Use Policy* (formación y atestación de personal)
- % de sistemas de IA de alto riesgo con revisión del Comité de Riesgo IA en los últimos 6 meses
- Número de proveedores de IA con evaluación de riesgos de terceros activa

KPIs de la Función MAPEAR (AI RMF):

- % de sistemas de IA con registro de activos completo (propietario, datos, geografías, proveedor)
- Número de sistemas de IA categorizados por nivel de impacto (bajo/medio/alto/crítico) / total catalogados
- % de pipelines de datos con linaje documentado y derechos contractuales verificados

KPIs de la Función MEDIR (AI RMF):

- Puntuación de *Model Card* (completitud del documento por sistema: propósito, datos, métricas, límites, propietarios, última revisión)^[3]
- Resultados de pruebas de sesgo/equidad (*demographic parity difference, equalized odds gap*)^[5]
- Tasa de robustez: rendimiento del modelo bajo entradas adversariales (inyección de prompt, ejemplos adversariales)^[5]
- Métricas de ciberresiliencia del modelo: resistencia a extracción, inversión y ataques de *fine-tuning*^[5]
- % de sistemas de IA con pruebas de penetración específicas de IA completadas en los últimos 12 meses

KPIs de la Función GESTIONAR (AI RMF):

- Tiempo medio de respuesta a incidentes de IA (MTTR-AI)
- % de riesgos IA identificados con tratamiento documentado y responsable asignado
- Número de incidentes de IA con lecciones aprendidas formalizadas / periodo
- % de planes de recuperación de sistemas IA críticos probados en los últimos 12 meses^[^6]

11.2. Las Siete Características de la IA Fiable como Marco de Métricas

El AI RMF organiza sus métricas de medición en torno a las **siete características de la IA fiable** (*Trustworthy AI*), que representan la taxonomía de calidad que toda organización debería poder cuantificar para sus sistemas de IA:^{[^7][^8]}

Característica	Métricas de Referencia 2025	Relevancia FAICP
Válida y Fiable	Accuracy, F1-score, AUPRC, drift rate	Detección de degradación del modelo
Segura	Tasa de incidentes de seguridad IA, tiempo de parcheo, cobertura de sandboxing	Núcleo del FAICP
Protegida y Resiliente	Resistencia a inyección de prompt, extracción, inversión	Núcleo del FAICP
Transparente y Responsable	% modelos con documentación pública, audit trail completitud	Requerimiento EU AI Act Art. 13
Explicable e Interpretable	SHAP values, attention maps, fidelidad de explicaciones ^[^9]	XAI para cumplimiento GDPR/EU AI Act
Privacidad Mejorada	Tasa de datos PII en prompts, cobertura de redacción, métricas de anonimización	RGPD + EU AI Act
Equitativa (sin sesgo perjudicial)	Paridad demográfica, igualdad de oportunidades, métricas de equidad por grupo	EU AI Act Art. 10

La investigación académica revisada por pares de 2025 señala que la **ausencia de métricas estandarizadas para XAI en ciberseguridad** es una de las brechas más críticas del campo: técnicas como SHAP y mecanismos de atención mejoran la confianza de los analistas y el cumplimiento regulatorio, pero aún carecen de umbrales de referencia ampliamente aceptados.^[^9]

12. OWASP LLM Top 10 (2025): El Catálogo Operacional de Vulnerabilidades IA

12.1. Las Diez Vulnerabilidades y sus Métricas de Detección

La **OWASP Top 10 para Aplicaciones LLM (versión 2025)**, publicada el 18 de noviembre de 2024 y de plena vigencia en 2025, actualiza el catálogo con nuevas categorías que reflejan la madurez del campo y los incidentes reales documentados. Su valor para el marco FAICP radica en que es el único catálogo con base empírica en más de 2.000 aplicaciones LLM reales.^{[^10][^11][^12]}

Riesgo OWASP LLM 2025	ID	Métrica de Detección/Medición
Inyección de Prompt	LLM01	Intentos de inyección detectados/periodo; tasa de éxito de bypass
Divulgación de Información Sensible	LLM02	PII/datos sensibles en outputs; tasa de redacción efectiva
Cadena de Suministro	LLM03	% componentes con AI-BOM; vulnerabilidades de terceros activas
Envenenamiento de Datos y Modelo	LLM04	Cobertura de proveniencia de datos; canary tests; logs de cambios
Manejo Inadecuado de Salidas	LLM05	Validación de schemas; tasa de outputs que superan controles de políticas
Agencia Excesiva	LLM06	Scope de herramientas IA; tasa de aprobaciones humanas; límites de acción autónoma ^[13]
Filtración de Prompt de Sistema	LLM07	Intentos de extracción de prompt de sistema detectados; cobertura de tests ^[11]
Vulnerabilidades de Vectores y Embeddings	LLM08	Integridad de índices RAG; tests de envenenamiento de vectores
Desinformación	LLM09	Tasa de alucinaciones en producción; cobertura de verificación de hechos
Consumo Descontrolado	LLM10	Costes de inferencia por solicitud; tasa de solicitudes anómalas; límites de recursos ^[10] ^[14]

12.2. Impacto en el Contexto Español

La Guía 11 de AESIA sobre **Ciberseguridad para el RIA** (Art. 15, diciembre 2025) establece medidas específicas para que los sistemas de IA de alto riesgo en España sean resistentes a intentos de terceros de alterar su uso, resultados o funcionamiento. Esta guía —una de las primeras de su tipo publicadas por una autoridad regulatoria en Europa— se convierte en la referencia normativa directa para la implementación OWASP LLM en el contexto del EU AI Act. Las vulnerabilidades LLM01, LLM06 y LLM08 son particularmente relevantes para los sistemas de IA de alto riesgo (biometría, empleo, crédito, infraestructuras críticas) cuya adopción en España requiere registro y evaluación de conformidad.^[15]^[16]^[17]^[18]^[19]

13. El Plan Nacional de Ciberseguridad Reforzado: Inversión Histórica de 1.157 Millones

13.1. El Contexto que Justificó la Decisión

El 5 de mayo de 2025, el Consejo de Ministros aprobó **el mayor esfuerzo de inversión en ciberseguridad de la historia de España**: 1.157 millones de euros integrados en el Plan Industrial y Tecnológico para la Seguridad y la Defensa. El ministro Óscar López situó el diagnóstico con claridad meridiana: más de **100.000 ciberataques en 2024**, con uno clasificado como grave cada tres días, y un incremento del **300% de ciberataques en la última década**. El apagón del 28 de abril de 2025, cuya naturaleza (ciberataque o fallo técnico) permanecía bajo investigación en el momento de la aprobación del plan, actuó como catalizador político de la decisión.^{[20][21][22][23]}

13.2. Distribución de la Inversión y su Relevancia FAICP

El desglose presupuestario revela las prioridades estratégicas del Estado:^[22]

Organismo	Asignación	% del Total	Relevancia FAICP
Ministerio de Defensa (CCN/CNI)	700 M€	60,4%	Ciberdefensa, inteligencia de amenazas IA
Ministerio de Transformación Digital (INCIBE/Red.es)	255 M€	22,0%	Ecosistema civil, PYME, formación, INCIBE-CERT
Ministerio del Interior	189 M€	16,3%	Cuerpos y fuerzas seguridad, infraestructura crítica
Departamento de Seguridad Nacional (DSN)	14 M€	1,2%	Coordinación estratégica nacional

La partida de **255 millones para el Ministerio de Transformación Digital** es la que más directamente alimenta la capacidad FAICP civil española: financiará el fortalecimiento tecnológico de INCIBE, la mejora de la protección de infraestructuras críticas, programas de I+D en ciberseguridad e IA, y la expansión de la colaboración público-privada. La integración explícita de la **inteligencia artificial y la computación cuántica** como tecnologías disruptivas que motivan la actualización del Plan Nacional de Ciberseguridad constituye el respaldo institucional más sólido hasta la fecha para el enfoque FAICP a nivel estatal.^{[21][24][20]}

14. Ciberseguridad Industrial y OT: El Flanco Más Expuesto del Territorio

14.1. Datos de Exposición ICS/OT en España (2025)

El **19,4% de los ordenadores de sistemas de control industrial (ICS) en el sur de Europa** detectó y bloqueó intentos de ciberataque en el segundo trimestre de 2025, según Kaspersky ICS CERT. España

se sitúa en torno a la media regional (ligeramente por debajo del global 20,5%), pero muy por encima de Europa del Norte (11,2%). Los vectores de ataque más destacados en entornos ICS españoles son:[^25]

- Correo electrónico: 7,8% de ordenadores ICS afectados (por encima de la media sur-europea del 7,23%)[^25]
- Internet: 8,09% de ordenadores ICS con ataques bloqueados procedentes de la red[^25]
- Sectores más afectados en el sur de Europa: biometría (34,2%), automatización de edificios (26,3%), muy por encima de energía eléctrica (14,8%) o manufactura (12,8%)[^25]

A nivel europeo, el **ENISA Threat Landscape 2025** documenta que los ataques OT representan el **18,2% de todas las ciberamenazas EU**, con manufactura alcanzando una tasa del **59,3% de incidentes de cibercrimen**. El uso de malware ICS específico (análogo a CRASHOVERRIDE o INDUSTROYER2) sigue creciendo, impulsado en parte por técnicas de IA adversarial para reconocimiento y escalada.[^26]

14.2. El CCI y el Marco MACIN/SG2CI (España, 2025)

El **Centro de Ciberseguridad Industrial (CCI)**, con una comunidad que supera los **9.000 profesionales** en España, lanzó en 2025 dos instrumentos de medición específicamente diseñados para el entorno OT:[^27]

- MACIN (Marco de Evaluación de Ciberresiliencia Industrial): plataforma para evaluar la madurez y ciberresiliencia industrial con métricas OT-específicas[^27]
- SG2CI (Sistema de Gobierno para la Gestión de la Ciberseguridad Industrial): marco operativo para el nuevo rol ICSO (Industrial Cybersecurity Officer)[^27]

Estos instrumentos nacionales representan la contrapartida española al **ISA/IEC 62443** (estándar de referencia para ciberseguridad OT/ICS) y su integración con los indicadores FAICP es una de las tareas pendientes más urgentes, especialmente considerando que la Guía Técnica ENISA NIS2 incluye requisitos específicos para entornos operacionales.[^27][^25]

Indicadores FAICP aplicables al entorno OT/ICS en CCAA con tejido industrial:

- % de activos OT/ICS con inventario documentado y evaluación de riesgos IA-específica
- Tiempo medio de detección de malware ICS en entornos sin conectividad IT/OT separada
- Número de incidentes de ransomware industrial con componente IA adversarial documentado / periodo
- Cobertura de segmentación de red IT/OT en instalaciones con sistemas de control industrial
- % de sistemas SCADA/DCS con versiones de firmware actualizadas en los últimos 6 meses

Para las CCAA con mayor densidad industrial —**País Vasco** (con ZIUR como referente OT), **Cataluña** (sector químico y automotriz), **Comunidad Valenciana** (cerámica, agroalimentaria) y **Aragón** (logística y energía)—, estos indicadores adquieren máxima prioridad estratégica en el marco FAICP territorial.[^28]

15. Las 16 Guías AESIA: El Mapa de Cumplimiento FAICP para España

15.1. La Guía 11 de AESIA: El Indicador de Ciberseguridad IA más Específico de España

El 16 de diciembre de 2025, AESIA publicó **16 guías prácticas para el cumplimiento del Reglamento de Inteligencia Artificial (RIA/EU AI Act)**, resultantes del piloto del *AI Regulatory Sandbox* español —el primero de Europa. Las guías, no vinculantes pero con alto valor interpretativo, constituyen uno de los primeros conjuntos de criterios interpretativos estructurados emitidos por una autoridad pública en Europa.^{[29][16][17][19]}

La **Guía 11 (Ciberseguridad, 79 páginas)** incluye una lista de medidas de ciberseguridad con orientación práctica para su implementación bajo el Art. 15 del RIA, cubriendo la resistencia de los sistemas de IA de alto riesgo a ataques externos. Su estructura de indicadores se alinea directamente con el NIST IR 8596 aunque desde una perspectiva regulatoria:^{[17][18]}

Medidas de la Guía 11 AESIA con expresión métrica:

- Resistencia a manipulación de entradas (prompt injection, entradas adversariales): medida por tasa de intentos bloqueados / total de intentos
- Integridad del modelo en producción: verificación periódica de firma digital del modelo vs. versión autorizada
- Auditoría de accesos a sistemas de IA de alto riesgo: logs con retención mínima según Art. 12 RIA
- Gestión de incidentes graves de IA (Art. 73): tiempo de notificación a AESIA ≤ 15 días hábiles^[15]
- Vigilancia poscomercialización (Art. 72): métricas de rendimiento en producción vs. umbrales definidos en conformidad

La **Guía 10 (Solidez/Robustez)** complementa la 11 con métricas de resistencia a errores, fallos e incoherencias, y la **Guía 9 (Precisión)** establece el marco para evaluar el desempeño técnico del sistema. Juntas, las guías 9, 10 y 11 de AESIA constituyen la **triada de indicadores de calidad IA** más relevante para la implementación FAICP en organizaciones españolas sujetas al EU AI Act.^{[18][30]}

15.2. El Checklist de los 12 Requisitos AESIA

Las guías AESIA incluyen una herramienta *checklist* en Excel para los **12 requisitos de diagnóstico** de sistemas de IA de alto riesgo, directamente convertible en un cuadro de mando FAICP:^[19]

1. Sistema de gestión de calidad (Guía 4)
2. Sistema de gestión de riesgos (Guía 5)
3. Supervisión humana (Guía 6)
4. Datos y gobernanza de datos (Guía 7/8)
5. Transparencia (Guía de transparencia)
6. Precisión (Guía 9)
7. Solidez/Robustez (Guía 10)
8. Ciberseguridad (Guía 11)
9. Registros y logs automáticos (Guía 12)
10. Documentación técnica
11. Vigilancia poscomercialización
12. Gestión de incidentes graves

Cada ítem del checklist se convierte en un indicador binario (cumple/no cumple) o en una escala de madurez (0-4) análoga a la del CMMC o del ENS. La automatización de esta evaluación mediante plataformas GRC IA es el siguiente paso lógico que el ecosistema español de ciberseguridad aún no ha dado de forma estandarizada.[^30]

16. Análisis Comparativo de Madurez: España vs. Economías de Referencia (2025)

16.1. Posicionamiento en el Índice Global de Madurez en Ciberseguridad

El **Global Cybersecurity Index de la UIT 2024** (publicado en 2025 y válido como referencia actual) posiciona a España en **Tier 1** (mayor nivel de compromiso), junto con Alemania, Francia, Países Bajos, Reino Unido, EE.UU. y Corea del Sur. Sin embargo, este índice mide capacidades nacionales de ciberseguridad, no la madurez específica IA-ciberseguridad (FAICP), donde las diferencias son más pronunciadas.[^31]

16.2. El Diferencial IA-Ciberseguridad: España frente a Líderes Mundiales

El **WEF Global Cybersecurity Outlook 2025** establece una brecha sistémica entre capacidades de ciberseguridad general y capacidades específicas de seguridad IA que afecta a todos los países, incluidos los líderes:[^32][^33]

País / Grupo	Madurez Ciber General	Procesos Evaluación IA Pre-Despliegue	AI Fortification "Mature"
EE.UU.	Alta	43% (WEF)	~10% (Cisco CRI)
UE (media)	Alta	37% (WEF)	7% (Cisco CRI)
España	Alta (Tier 1 UIT)	n.d. (estimado ~35%)	7% (Cisco CRI)
APAC líderes	Alta	~30%	8%
Global	Variable	37%	7%

El **déficit de España en Identity Intelligence** (solo 3% en nivel "Mature", frente al 6% global) es el indicador individual más preocupante: la gestión de identidades es la primera línea de defensa en todos

los vectores IA adversariales, y su debilidad relativa compromete la eficacia de cualquier otro control FAICP.[³⁴]

16.3. Fortalezas Diferenciales de España en el Contexto FAICP Global

España cuenta con activos únicos que la posicionan favorablemente para liderar la implementación FAICP en el sur de Europa:

- AESIA operativa — única autoridad supervisora de IA en la UE con capacidad sancionadora real[¹⁶][²⁹]
- AI Regulatory Sandbox — laboratorio de pruebas regulatorias que genera las guías más detalladas de Europa sobre cumplimiento del EU AI Act[¹⁶]
- INCIBE como hub europeo — 122.223 incidentes gestionados en 2025, datos de amenazas que alimentan indicadores FAICP con base empírica nacional[³⁵]
- CCI y ecosistema OT — referente industrial con marcos propios (MACIN, SG2CI) adaptados al tejido productivo español[²⁷]
- Inversión histórica de 1.157M€ — señal política y presupuestaria sin precedentes que financia la arquitectura institucional FAICP[²¹]
- CyberHub Spain — estrategia de talento en ciberseguridad que identifica explícitamente la AI security como especialización crítica deficitaria[³⁶]

17. Brechas Críticas y Agenda de Investigación FAICP para España 2026-2028

17.1. Brechas Identificadas en las Fuentes Primarias

La investigación exhaustiva realizada permite identificar las siguientes lagunas que ninguna fuente primaria cubre de forma satisfactoria:

Brecha 1 — Ausencia de índice territorial CCAA: No existe, a abril de 2026, ningún documento público oficial que desagregue indicadores de madurez en ciberseguridad (y menos aún de FAICP) a nivel de Comunidad Autónoma. La brecha no es técnica sino de gobernanza: no hay mecanismo de reporte autonómico estandarizado análogo al NCAF de ENISA para estados miembros.[³⁷]

Brecha 2 — Métricas de IA adversarial en entornos de administración pública: El VI Indicador ISMS Forum evalúa madurez CSF en organizaciones españolas pero no incluye subcategorías específicas de IA adversarial ni vectores del NIST IR 8596. La próxima edición (VII, 2026) debería incorporar estas dimensiones.[³⁸]

Brecha 3 — Estandarización de AI-BOM en España: El inventario de componentes de IA (*AI Bill of Materials*) es un indicador Nivel-1 del NIST IR 8596 (ID.AM-07) pero no existe referencia regulatoria española que lo exija, aunque el Art. 11 del EU AI Act sobre documentación técnica lo aproxima.[³⁹][¹⁷]

Brecha 4 — Métricas de XAI para ciberseguridad: La literatura académica revisada por pares de 2025 identifica de forma unánime la ausencia de métricas estandarizadas para evaluar la explicabilidad

de sistemas de IA en contextos de ciberseguridad. Sin estas métricas, los indicadores FAICP carecen de la dimensión de *accountability* que el EU AI Act y el GDPR exigen.[⁹]

Brecha 5 — Tiempo de respuesta a incidentes IA (MTTR-AI): Ningún informe sectorial español publica datos de MTTR específicos para incidentes donde la IA es vector de ataque (a diferencia del MTTR general). El ENISA ETL 2025 no desagrega este dato por vectores IA.[⁴⁰]

17.2. Agenda de Investigación Propuesta

Para cerrar las brechas identificadas, se propone la siguiente agenda de investigación y actuación para el período 2026-2028, orientada tanto al ámbito académico como institucional:

Línea 1 — Observatorio FAICP Territorial:

Diseño e implementación de un observatorio de indicadores FAICP con desagregación por CCAA, basado en los datos existentes de INCIBE (incidentes territorializables), CCN-CERT (ENS compliance), AESIA (registros de IA alto riesgo) y CCI (madurez OT). El modelo metodológico de referencia es el *National Cyber Security Index* (NCSI) de Estonia, adaptado al marco regulatorio español.

Línea 2 — Integración FAICP en ENS Rev. 3:

Propuesta de incorporación de subcategorías específicas de IA en la próxima revisión del Esquema Nacional de Seguridad, tomando como base el mapeo NIST IR 8596 → ENS desarrollado en el Apéndice Metodológico del Informe FAICP Parte I.

Línea 3 — Estudio Longitudinal de Madurez FAICP en AAPP Autonómicas:

Replicación de la metodología del VI Indicador ISMS Forum con una muestra estratificada por CCAA y sector de administración pública (sanitario, educativo, tributario, seguridad) para obtener la primera línea de base territorial de madurez FAICP en España.[³⁸]

Línea 4 — Métricas XAI para SOC (Security Operations Centers):

Investigación aplicada sobre la medición de la explicabilidad de sistemas de IA en operaciones de ciberseguridad, con el objetivo de desarrollar el estándar mínimo exigible por el EU AI Act en contextos de alto riesgo.[⁴¹][⁹]

Línea 5 — Piloto de AI-BOM en Administración Pública:

Desarrollo de un piloto de implementación de *AI Bill of Materials* en tres administraciones autonómicas voluntarias, con metodología transferible al resto del territorio. AESIA y INCIBE como facilitadores; ENISA como referencia técnica.

18. Síntesis de Indicadores FAICP: El Cuadro de Mando Integral para España

La siguiente tabla integra los indicadores más operacionalizables de todos los marcos analizados, organizados por función FAICP y con indicación del nivel de aplicabilidad para España (Nacional / CCAA / Organización):

Indicador FAICP	Función	Marco de Origen	Nivel Aplicabilidad	Dato de Referencia 2025
% sistemas IA alto riesgo con evaluación de conformidad AESIA	Gobernar	EU AI Act + AESIA Guía 3	Nacional/CCAA	n.d. (en construcción)
Políticas de uso IA publicadas / total organismos AAPP	Gobernar	NIST IR 8596 GV.OC-04	CCAA	n.d.
Incidentes gestionados INCIBE / 100.000 hab.	Identificar/ Detectar	INCIBE + NCS Guide	Nacional/CCAA	~2,5/100K (2025) [^35]
Sistemas vulnerables identificados / 1.000 empresas	Identificar	INCIBE	Nacional	~4,8 (estimado) [^35]
% organizaciones con inventario completo de activos IA (AI-BOM)	Identificar	NIST IR 8596 ID.AM-07	Organización	n.d.
% sistemas IA con controles de menor privilegio activos	Proteger	NIST IR 8596 PR.AA-05	Organización	<40% (estimado) [^38]
Madurez "AI Fortification" nivel Mature	Proteger	Cisco CRI 2025	Nacional	7%[^34]
% empleados formados deepfake/AI-phishing	Proteger	NIST IR 8596 PR.AT-01	Organización	38% optimizado[^38]
% APIs IA externas con monitorización de tráfico activa	Detectar	NIST IR 8596 DE.CM-06	Organización	40% (visibilidad prompts)[^34]
Tiempo medio detección model drift (días)	Detectar	AI RMF MEASURE	Organización	n.d.

MTTR-AI (tiempo respuesta incidentes IA, días)	Responder	NIST IR 8596 RS.AN-03	Organización	n.d.
% sistemas IA críticos con backup de modelo verificado	Recuperar	NIST IR 8596 RC.RP-02	Organización	n.d.
% ICS con ataques detectados/bloqueados Q2-2025	OT/ICS	Kaspersky ICS CERT	Nacional	19,4% ^[25]
Ransomware industrial como % total incidentes EU	OT/ICS	ENISA ETL 2025	EU/Nacional	81,1% ^[42]
% administraciones CCAA con ENS compliance verificado	Gobernar	ENS RD 311/2022	CCAA	n.d. (fragmentado)
Inversión en ciberseguridad per cápita (€/habitante)	Gobernar	Plan Nacional Ciber	Nacional	~24,5€/hab (1.157M/47,4M) ^[22]

19. El Horizonte 2026-2028: Qué Esperar del Ecosistema FAICP

19.1. Hitos Regulatorios y Técnicos Confirmados

El calendario de eventos que moldearán los indicadores FAICP en España durante los próximos dos años está notablemente poblado:

- Agosto 2026: Plena aplicabilidad del EU AI Act para sistemas de IA de alto riesgo (nuevos sistemas). Primera oleada de evaluaciones de conformidad supervisadas por AESIA.^[43]
- 2026 (en curso): Publicación del NIST IR 8596 en versión final tras el cierre del período de comentarios del borrador preliminar.^[44]
- 2026: Entrada en aplicación del Cyber Resilience Act (CRA), que establece requisitos de ciberseguridad para todos los productos con elementos digitales en el mercado UE, incluyendo dispositivos IoT y componentes de IA embebida.^[27]
- 2026-2027: Revisión del Plan Nacional de Ciberseguridad español que incorpore explícitamente la dimensión IA-ciberseguridad (FAICP) como vector autónomo, financiado por los 255M€ del Ministerio de Transformación Digital.^[24]^[20]
- 2027: Primera evaluación de cumplimiento DORA (Digital Operational Resilience Act) en el sector financiero español, incluyendo indicadores de resiliencia ante fallos de sistemas IA.^[27]

19.2. La Inteligencia Artificial Autónoma como Próxima Frontera del FAICP

El cambio más disruptivo en el horizonte no es regulatorio sino tecnológico: la emergencia de **sistemas de IA autónomos independientes** (*standalone malicious AI systems*), documentada por ENISA desde el inicio de 2025, redefine el perímetro del FAICP. A diferencia de los ataques que *usan* IA para potenciar técnicas existentes (phishing, exploits), los sistemas autónomos maliciosos como **Xanthorox AI** y variantes de **FraudGPT** operan de forma independiente, sin supervisión humana constante, con capacidades de reconocimiento, evasión y adaptación que superan las métricas de detección diseñadas para amenazas convencionales.^{[45][40][26]}

MITRE ATLAS, con sus **14 nuevas técnicas para IA agéntica** añadidas en 2025, y el NIST IR 8596 con sus overlays COSAiS, son los dos marcos que más directamente abordan esta frontera. Su integración en los indicadores FAICP de la siguiente generación —y en la arquitectura de detección de los SOC nacionales y autonómicos españoles— es la tarea técnica más urgente y menos consolidada de cuantas se han analizado en este informe.^{[46][39]}

Parte II elaborada con datos primarios verificados a abril de 2026. Este documento es continuación del Informe FAICP 2025–2026 Parte I y debe leerse conjuntamente con él para una comprensión integral del marco.

References

13.
The Essential Guide to the NIST AI Risk Management Framework 1.0 - The NIST AI Risk Management Framework 1.0 Official gives teams a way to evaluate AI use more consist...
14.
AI RMF Core - AIRC - NIST AI Resource Center - The AI RMF Core provides outcomes and actions that enable dialogue, understanding, and activities to...
15.
NIST AI RMF in Plain English: Govern, Map, Measure, Manage ... - The NIST AI Risk Management Framework (AI RMF) is fast becoming the common language for building and...
16.
NIST AI Risk Management Framework Guide - VerifyWise - Implement the NIST AI Risk Management Framework (AI RMF 1.0) with VerifyWise. Map controls across Go...
17.
NIST AI Risk Management Framework (AI RMF 1.0) - Nemko Digital - Master the NIST AI Risk Management Framework to safeguard AI systems in 2025. Learn proven strategie...
18.
Core Functions: Govern, Map, Measure, Manage - IS Partners, LLC - The NIST AI RMF outlines requirements for developing and deploying trustworthy AI systems, focusing ...
19.
NIST AI 100-1: Artificial Intelligence Risk Management Framework ... - NIST's AI RMF 1.0 is a voluntary, technology- and sector-agnostic framework for managing risks arisi...
20.
Understanding the NIST AI Risk Management Framework - Explore the AI Risk Management Blueprint, Characteristics of Trustworthy AI, AI Risk Categories & Ho...
21.
[PDF] Improving cybersecurity through explainable artificial intelligence - This systematic literature review examines how. Explainable AI (XAI) bridges the gap between advance...
22.
Secure your LLM apps with OWASP's 2025 Top 10 for LLMs and ... - OWASP officially released the 2025 version of the "OWASP Top 10 for LLM Applications" on Nov 18, 202...

23.
Strengthening LLM Security: Insights from OWASP's 2025 ...
24.
[PDF] OWASP Top 10 for LLM Applications 2025 - Use Static Application Security Testing (SAST) and Dynamic and Interactive application testing (DAST...
25.
Understanding the 2025 OWASP Top 10 for LLM Applications - An overview of the new OWASP list of Top 10 threats posed by Large Language Models and how to mitiga...
26.
OWASP Releases Updated 2025 Top 10 Risks for LLMs - - The OWASP Foundation has released the 2025 edition of its Top 10 Risks for LLM Applications and Gene...
27.
AESIA [Spain] Guidance on EU AI Act | Carolina Quijano Mallarino - The Spanish Agency for the Supervision of Artificial Intelligence [AESIA] has issued an English vers...
28.
AESIA's AI Guidelines: Spain steps into the AI spotlight - IAPP - Developed within Spain's AI regulatory sandbox pilot, the guidelines draw on real-world testing of A...
29.
EU AI Act Compliance: Guidance from the Spanish AI Regulator - Among the examples, AESIA describes scenarios such as biometric identification systems in the workpl...
30.
LA AESIA PUBLICA 16 GUÍAS PARA ORIENTAR EL ... - Prodat - La AESIA lanza 16 guías prácticas para facilitar el cumplimiento del Reglamento Europeo de Inteligen...
31.
Guías prácticas para el cumplimiento del RIA - la AESIA - Guías prácticas para el cumplimiento del RIA
32.
El Gobierno aprueba un refuerzo de las capacidades de España en ... - El conjunto de actuaciones permitirá mejorar las capacidades de ciberseguridad y ciberdefensa de amp...

33.
1.157 millones de euros para proteger nuestro futuro digital - ISMS Forum Spain es una Asociación española sin ánimo de lucro, cuyo principal objetivo es fomentar ...
34.
El Gobierno aprueba un plan de 1.157 millones para reforzar ... - El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad y ciberdefensa de Espa...
35.
El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad - España sufrió más de 100.000 ciberataques el año pasado, uno grave cada tres días, el 70% contra adm...
36.
El Gobierno aprueba un refuerzo de las capacidades ... - La extensión de las infraestructuras digitales, la evolución del contexto geopolítico, los retos que...
37.
El 19,4% de los sistemas industriales en España sufrió ciberataques ... - En el segundo trimestre de 2025, España registró un 7,05% de ordenadores ICS afectados por intentos ...
38.
ENISA Threat Landscape 2025: Critical OT Security Risks Every ... - ENISA's 2025 report reveals OT attacks now represent 18.2% of cyber threats. Manufacturing faces 59....
39.
La ciberseguridad industrial en 2025 y la estrategia del CCI para 2026 - Aumento del ransomware industrial y de las campañas de APTs dirigidas a infraestructuras críticas. M...
40.
Spain recorded more than 97000 cybersecurity incidents in 2024, 32 ... - The latest news from the ZIUR Industrial Cybersecurity Center in Gipuzkoa.
41.
Support guides for compliance with the AI Act published - AESIA - This is a set of 16 practical guides that aim to support the implementation and compliance of the Ar...
42.
AESIA impulsa el cumplimiento del Reglamento europeo ... - La Agencia Española de Supervisión de la Inteligencia Artificial (AESIA) ha publicado 16 guías y un ...

43.

5. National Cybersecurity Strategy Good Practice - NCS Guide 2025 - This section introduces a set of good-practice elements that can make the Strategy comprehensive and...

44.

Global Cybersecurity Outlook 2025 - The World Economic Forum - While 66% of organizations expect AI to have the most significant impact on cybersecurity in the yea...

45.

World Economic Forum Releases Global Cybersecurity Outlook 2025 - While 66% of organisations expect AI to have a major impact on cybersecurity in 2025, only 37% repor...

46.

2025 Cisco Cybersecurity Readiness Index

47.

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un 26% más que el año anterior · Malwa...

48.

[PDF] - Cybersecurity skills strategy Spain. - CyberHubs - Once established, the Spanish CyberHub will define the Key Performance Indicators (KPIs) for each in...

49.

National Cybersecurity Strategies - ENISA - European Union - This report presents the work performed by ENISA to build a National Capabilities Assessment Framewo...

50.

[PDF] V Indicador de madurez en ciberseguridad - ISMS Forum Spain - En 2025, los resultados reflejan una evolución equilibrada entre la gestión de activos, los procedim...

51.

NIST Cybersecurity Framework Profile for AI - Libertify.com - NIST Internal Report NIST IR 8596 iprd. Cybersecurity Framework Profile for. Artificial Intelligence...

52.

[PDF] ENISA THREAT LANDSCAPE 2025 - The increased integration of AI systems into enterprise environments introduces a potentially vulner...

53.

Exploring the Role of Artificial Intelligence in Enhancing Security ... - This systematic literature review analyses AI's transformative impact across the NIST Cybersecurity ...

54.

ENISA Cybersecurity Threat Landscape Report 2025 - 1. The core threat: Driven by profit · 2. How attackers break in: Phishing and exploits · 3. The amp...

55.

EU AI Act Spain Implementation Guide 2025 | AESIA Compliance - AESIA supervisory agency, Spain's AI regulatory sandbox, national AI law, and compliance requirement...

56.

Draft NIST Guidelines Rethink Cybersecurity for the AI Era - The Cyber AI Profile centers on three overlapping focus areas: securing AI systems, conducting AI-en...

57.

[PDF] ENISA THREAT LANDSCAPE 2025 - By early 2025, AI- supported phishing campaigns reportedly represented more than 80 percent of obser...

58.

MITRE ATLAS Framework 2026 - Guide to Securing AI Systems - What is the MITRE ATLAS Framework? The MITRE ATLAS (Adversarial Threat Landscape for Artificial-Inte...

The Essential Guide to the NIST AI Risk Management Framework 1.0 - The NIST AI Risk Management Framework 1.0 Official gives teams a way to evaluate AI use more consist...

AI RMF Core - AIRC - NIST AI Resource Center - The AI RMF Core provides outcomes and actions that enable dialogue, understanding, and activities to...

NIST AI RMF in Plain English: Govern, Map, Measure, Manage ... - The NIST AI Risk Management Framework (AI RMF) is fast becoming the common language for building and...

NIST AI Risk Management Framework Guide - VerifyWise - Implement the NIST AI Risk Management Framework (AI RMF 1.0) with VerifyWise. Map controls across Go...

NIST AI Risk Management Framework (AI RMF 1.0) - Nemko Digital - Master the NIST AI Risk Management Framework to safeguard AI systems in 2025. Learn proven strategie...

Core Functions: Govern, Map, Measure, Manage - IS Partners, LLC - The NIST AI RMF outlines requirements for developing and deploying trustworthy AI systems, focusing ...

NIST AI 100-1: Artificial Intelligence Risk Management Framework ... - NIST's AI RMF 1.0 is a voluntary, technology- and sector-agnostic framework for managing risks arising...

Understanding the NIST AI Risk Management Framework - Explore the AI Risk Management Blueprint, Characteristics of Trustworthy AI, AI Risk Categories & Ho...

[PDF] Improving cybersecurity through explainable artificial intelligence - This systematic literature review examines how. Explainable AI (XAI) bridges the gap between advance...

Secure your LLM apps with OWASP's 2025 Top 10 for LLMs and ... - OWASP officially released the 2025 version of the "OWASP Top 10 for LLM Applications" on Nov 18, 202...

Strengthening LLM Security: Insights from OWASP's 2025 ...

[PDF] OWASP Top 10 for LLM Applications 2025 - Use Static Application Security Testing (SAST) and Dynamic and Interactive application testing (DAST...

Understanding the 2025 OWASP Top 10 for LLM Applications - An overview of the new OWASP list of Top 10 threats posed by Large Language Models and how to mitiga...

OWASP Releases Updated 2025 Top 10 Risks for LLMs - - The OWASP Foundation has released the 2025 edition of its Top 10 Risks for LLM Applications and Gene...

AESIA [Spain] Guidance on EU AI Act | Carolina Quijano Mallarino - The Spanish Agency for the Supervision of Artificial Intelligence [AESIA] has issued an English vers...

AESIA's AI Guidelines: Spain steps into the AI spotlight - IAPP - Developed within Spain's AI regulatory sandbox pilot, the guidelines draw on real-world testing of A...

EU AI Act Compliance: Guidance from the Spanish AI Regulator - Among the examples, AESIA describes scenarios such as biometric identification systems in the workpl...

LA AESIA PUBLICA 16 GUÍAS PARA ORIENTAR EL ... - Prodat - La AESIA lanza 16 guías prácticas para facilitar el cumplimiento del Reglamento Europeo de Inteligen...

Guías prácticas para el cumplimiento del RIA - la AESIA - Guías prácticas para el cumplimiento del RIA

El Gobierno aprueba un refuerzo de las capacidades de España en ... - El conjunto de actuaciones permitirá mejorar las capacidades de ciberseguridad y ciberdefensa de amp...

1.157 millones de euros para proteger nuestro futuro digital - ISMS Forum Spain es una Asociación española sin ánimo de lucro, cuyo principal objetivo es fomentar ...

El Gobierno aprueba un plan de 1.157 millones para reforzar ... - El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad y ciberdefensa de Espa...

El Gobierno aprueba un plan de 1.157 millones para reforzar la ciberseguridad - España sufrió más de 100.000 ciberataques el año pasado, uno grave cada tres días, el 70% contra adm...

El Gobierno aprueba un refuerzo de las capacidades ... - La extensión de las infraestructuras digitales, la evolución del contexto geopolítico, los retos que...

El 19,4% de los sistemas industriales en España sufrió ciberataques ... - En el segundo trimestre de 2025, España registró un 7,05% de ordenadores ICS afectados por intentos ...

ENISA Threat Landscape 2025: Critical OT Security Risks Every ... - ENISA's 2025 report reveals OT attacks now represent 18.2% of cyber threats. Manufacturing faces 59....

La ciberseguridad industrial en 2025 y la estrategia del CCI para 2026 - Aumento del ransomware industrial y de las campañas de APTs dirigidas a infraestructuras críticas. M...

Spain recorded more than 97000 cybersecurity incidents in 2024, 32 ... - The latest news from the ZIUR Industrial Cybersecurity Center in Gipuzkoa.

Support guides for compliance with the AI Act published - AESIA - This is a set of 16 practical guides that aim to support the implementation and compliance of the Ar...

AESIA impulsa el cumplimiento del Reglamento europeo ... - La Agencia Española de Supervisión de la Inteligencia Artificial (AESIA) ha publicado 16 guías y un ...

5. National Cybersecurity Strategy Good Practice - NCS Guide 2025 - This section introduces a set of good-practice elements that can make the Strategy comprehensive and...

Global Cybersecurity Outlook 2025 - The World Economic Forum - While 66% of organizations expect AI to have the most significant impact on cybersecurity in the yea...

World Economic Forum Releases Global Cybersecurity Outlook 2025 - While 66% of organisations expect AI to have a major impact on cybersecurity in 2025, only 37% repor...

2025 Cisco Cybersecurity Readiness Index

INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un ... - INCIBE gestionó 122.223 incidentes de ciberseguridad en 2025, un 26% más que el año anterior · Malwa...

[PDF] - Cybersecurity skills strategy Spain. - CyberHubs - Once established, the Spanish CyberHub will define the Key Performance Indicators (KPIs) for each in...

National Cybersecurity Strategies - ENISA - European Union - This report presents the work performed by ENISA to build a National Capabilities Assessment Framewo...

[PDF] V Indicador de madurez en ciberseguridad - ISMS Forum Spain - En 2025, los resultados reflejan una evolución equilibrada entre la gestión de activos, los procedim...

NIST Cybersecurity Framework Profile for AI - Libertify.com - NIST Internal Report NIST IR 8596 iprd. Cybersecurity Framework Profile for. Artificial Intelligence...

[PDF] ENISA THREAT LANDSCAPE 2025 - The increased integration of AI systems into enterprise environments introduces a potentially vulner...

Exploring the Role of Artificial Intelligence in Enhancing Security ... - This systematic literature review analyses AI's transformative impact across the NIST Cybersecurity ...

ENISA Cybersecurity Threat Landscape Report 2025 - 1. The core threat: Driven by profit · 2. How attackers break in: Phishing and exploits · 3. The amp...

EU AI Act Spain Implementation Guide 2025 | AESIA Compliance - AESIA supervisory agency, Spain's AI regulatory sandbox, national AI law, and compliance requirement...

Draft NIST Guidelines Rethink Cybersecurity for the AI Era - The Cyber AI Profile centers on three overlapping focus areas: securing AI systems, conducting AI-en...

[PDF] ENISA THREAT LANDSCAPE 2025 - By early 2025, AI- supported phishing campaigns reportedly represented more than 80 percent of obser...

MITRE ATLAS Framework 2026 - Guide to Securing AI Systems - What is the MITRE ATLAS Framework? The MITRE ATLAS (Adversarial Threat Landscape for Artificial-Inte...